ITA CHALLENGE SPRINT · DESAFIO 2 · STARK BANK

GerencIA
Dossiê consolidado

Rastreabilidade e governança de informações em ferramentas de IA. As cinco semanas, num documento só.

01 **Semana 1** — Diagnóstico do problema

02 **Semana 2** — Hipótese de solução

03 **Semana 3** — Protótipo V1 e arquitetura

05 **Semana 5** — Dossiê final e proposta de valor

650 eventos · 14 regras · 15/15 do gabarito · 98,8% de concordância · dados fictícios

ITA CHALLENGE SPRINT · SEMANA 1 · DIAGNÓSTICO DO PROBLEMA

A empresa registra o uso de IA. Não consegue confiar no registro.

Governança de informação em ferramentas de IA no Stark Bank. Nesta primeira semana definimos o problema, provamos que ele existe na própria base da empresa e recortamos o que cabe no Sprint.

GERENCIA · RASTREABILIDADE E GOVERNANÇA DE IA · BASE OFICIAL: 650 EVENTOS · 72 USUÁRIOS · 8 FERRAMENTAS · 14 REGRAS

A DECISÃO QUE PRECISA MELHORAR

Como o Compliance decide o que é risco — e como audita essa decisão depois.

Hoje cada uso de IA já chega com uma classificação de risco e uma regra citada. Mas a classificação é **confiada, não verificada**, e não há linhagem que ligue uma informação às ferramentas e às pessoas por onde ela passou.

Hoje

Log de atividade

“O usuário X acessou a ferramenta Y às 14h.” O registro existe, mas responde à pergunta errada e ninguém confere se a regra citada corresponde ao que aconteceu.

Recorte proposto

Linhagem da informação

“A chave/API secret apareceu em 5 ferramentas, com 30 pessoas, 35 vezes — 3 em IA pública.” A busca começa no documento, reaplica a política e audita a rotulagem.

POR QUE É RELEVANTE PARA O NEGÓCIO

Fintech regulada. O que vaza para uma IA pública não volta.

O Stark Bank opera sob LGPD e regulação bancária. O material que transita nas ferramentas de IA é exatamente o mais sensível — e a exposição é jurídica, de segurança e de propriedade intelectual ao mesmo tempo.

Dado pessoal · CPF

LGPD: obrigação de resposta de privacidade e possível comunicação ao titular e à ANPD.

Chave / API secret

Credencial exposta é acesso a sistema. Risco crítico em qualquer ferramenta, aprovada ou não.

Financeiro não divulgado

Informação material antes da hora — risco regulatório e de mercado.

Código confidencial

Propriedade intelectual do banco entregue a um modelo de terceiro.

Ferramenta não aprovada

12,3% dos usos ocorrem fora das ferramentas homologadas pela empresa.

IA pública

Conteúdo enviado pode alimentar treino e sair do controle do banco para sempre.

COMPROVAÇÃO POR EVIDÊNCIAS · AUDITORIA DA BASE OFICIAL

O problema não é hipótese. Está na base que a própria empresa entregou.

Reaplicamos as 14 regras da política aos 650 eventos e auditamos a rotulagem já existente. Seis achados, todos verificáveis célula a célula na planilha:

A-01	38	Eventos citam regra de “ferramenta aprovada”, mas ocorreram em **IA pública**. O nível pode estar certo; a trilha de auditoria induz o auditor a erro.
A-02	18	Fechados com regra genérica onde há regra específica (R04/R05/R06). A obrigação de LGPD desaparece do registro.
A-03	8	Conteúdo interno/confidencial no gerador de imagens “só público”. Deveriam ser Alto e virar alerta — não viraram.
A-04	6/14	Regras que **nunca disparam**. A política aparenta 14 controles e opera com 8.
A-05	47	Alertas “tratados” **sem data de tratamento**. O SLA de 24h é declarado, não medido.
A-06	38	Combinação que **nenhuma regra** cobre. Lacuna de política — propomos a regra R15.

COMPROVAÇÃO POR EVIDÊNCIAS · O NÚMERO QUE DECIDE

7 de 10

indicadores que a empresa **declara** divergem do que a base realmente mostra quando recalculada.

6,8% → 16,6%

Eventos **críticos**: a empresa subnotifica a própria exposição em ~2,4×.

61 → 72

Usuários ativos com IA: 11 pessoas a mais do que o painel oficial conta.

72% → ?

"Alertas tratados em 24h": **não apurável** — não existe carimbo de tempo.

Quando a decisão de governança se apoia num painel que erra por 2,4× para menos, a empresa acredita estar mais segura do que está.

QUEM É IMPACTADO

Cinco frentes, uma cadeia só.

Compliance / DPO

Audita sobre uma trilha que confunde registro com evidência. Precisa provar o fluxo, não só listá-lo.

Segurança / CISO

Segredos e código expostos a terceiros, sem visão de qual informação saiu por onde.

72 usuários · 12 áreas

Usam IA no trabalho real. Sem regra clara e consequência definida para os casos comuns.

Direção / Conselho

Toma decisão de risco sobre indicadores que erram por 2,4×. Exposição regulatória e reputacional.

Clientes / titulares

Dados pessoais podem alcançar uma IA pública sem a resposta de privacidade que a LGPD exige.

O elo que falta

Ninguém consegue, hoje, partir de uma informação e ver toda a sua trajetória. É esse elo que o projeto entrega.

QUAL IMPACTO O PROBLEMA GERA

O custo de não enxergar.

Regulatório

Dado pessoal em IA pública sem a resposta de privacidade prevista — exposição a LGPD e à regulação bancária, com a obrigação sumindo do registro (A-02).

Segurança / PI

Credenciais e código confidencial entregues a modelos de terceiros, sem trilha de qual informação, de quem, por onde.

Decisão sobre dado errado

Governança apoiada num painel que subnotifica o risco crítico em 2,4× e mede SLA que não é apurável.

Auditoria não conclusiva

A política aparenta 14 controles e opera com 8; a trilha induz o auditor a erro. Uma auditoria real não fecha.

O RECORTE DO PROJETO

O que cabe no Sprint — e o que fica de fora.

DENTRO DO PROTÓTIPO

- → **Busca reversa da informação** — do documento para as ferramentas e pessoas.
- → **Reaplicação da política** com ordem de precedência declarada e cadeia de evidências.
- → **Auditoria da rotulagem** existente: os seis achados e os indicadores recalculados.
- → **Alertas** por nível de risco, com filtros por área, usuário, ferramenta e período.
- → **Captura na borda** (extensão + sensor) como "presente", unificada ao legado da planilha.

FORA DO PROTÓTIPO

- × **Bloqueio ativo** (prevenção em linha). O sistema observa e governa; não interrompe o uso.
- × **Leitura de conteúdo cifrado** (MITM). O sensor registra metadado, nunca o texto.
- × **Detecção de paráfrase** no fingerprint — pega recorte e colagem, não reescrita.
- × **Integração de produção** com SIEM/IdP — mostramos o contrato, não a ligação final.
- × **Substituir o DLP** corporativo — demonstramos a camada, não trocamos a existente.

COMO ISTO RESPONDE AO CRITÉRIO DA SEMANA 1

Relevância e clareza do problema.

01 **Compreensão do problema**

Reenquadrado: o problema não é registrar uso, é **confiar no registro** e ter linhagem da informação.

02 **Relevância para o negócio**

Fintech sob LGPD e regulação bancária; o que transita nas IAs é o material mais sensível do banco.

03 **Comprovação por evidências**

Seis achados verificáveis e 7 de 10 indicadores divergentes — na própria base oficial, não em suposição.

04 **Recorte do projeto**

Rastreabilidade, reaplicação da política, auditoria e alertas sobre a base — bloqueio e MITM fora do escopo.

ITA CHALLENGE SPRINT · SEMANA 2 · HIPÓTESE DE SOLUÇÃO

GerencIA: rastrear a informação que entra na IA, e provar o risco.

Como a solução em desenvolvimento atende aos requisitos do Desafio 2 (Stark Bank): o funcionamento, o papel da IA, a linha de base contra a qual mediremos, a métrica e a meta, e os dados.

Base oficial: 650 eventos · 160 alertas · 8 ferramentas · 20 tipos de informação · 72 usuários · 14 regras · dados fictícios (declarado na planilha)

Funcionamento

Uma frase, depois o mecanismo

GerencIA rastreia a informação, não o clique. Em vez de "o usuário X abriu o ChatGPT às 14h", ela responde "a chave/API secret apareceu em 5 ferramentas, com 30 pessoas, 35 vezes — 3 em IA pública", reaplica a política de risco com cadeia de evidência e audita a própria rotulagem existente.

O mecanismo tem quatro movimentos:

- **Capturar na borda.** Três camadas complementares observam o uso de IA na estação do usuário e mandam o registro a um coletor central on-premise.
- **Resolver a identidade no sistema operacional.** Quem usou é o usuário logado na máquina — nunca decidido pela página.
- **Reaplicar a política com IA.** Um motor classifica a informação, decide o risco por precedência de regras e monta a cadeia de evidência; o que a regra não resolve sobe para uma LLM, que devolve aprendizado.
- **Unificar e investigar.** A planilha (legado) e as capturas ao vivo (presente) entram na mesma base e no mesmo motor; o painel dá busca reversa, alertas e indicadores recalculados.

O desenho

Arquitetura da solução

CAPTURA · BORDA

Extensão de navegador

Vê o **conteúdo** (prompt + resposta). Detectores e fingerprint rodam local.

CAPTURA · BORDA

Agente / serviço

Metadado de uso de IA em qualquer app. Sobe no boot, identifica o usuário logado.

CAPTURA · OPCIONAL

Proxy TLS (MITM)

Conteúdo de qualquer app, via interceptação corporativa. Só com aval de Segurança.

↓

Coletor central (on-premise)

Recebe as capturas, **resolve a identidade no SO** (usuário logado), grava a trilha em banco sob controle da empresa e regenera o painel.

↓

Motor de IA — classifica, decide o risco, audita

IA clássica (núcleo)

Detectores (CPF/CNPJ/Luhn/credencial) + fingerprint (MinHash/SimHash) + regras R01–R14 com **precedência** → risco + cadeia de evidência.

cascata ⇄ aprendizado

LLM (quando a regra não basta)

Linguagem natural no rastreio e na classificação; o que ela resolve **vira padrão** de volta para a IA clássica.

↓

Base unificada

Excel = **legado** · capturas ao vivo = **presente**. Mesma tabela, mesmo motor, distinguidos pela origem.

↓

Painel de governança

Investigação e prova para Compliance e Segurança.

`Panorama` `Rastrear (busca reversa)` `Alertas + evidência` `Auditoria` `Validação` `Política` `Inventário` `Captura`

Papel da IA

A IA é o núcleo — e é auditável

A IA **não é apoio**: as três decisões centrais da solução são feitas por IA — **classificar** a informação, **decidir** o risco e **rastrear** em linguagem natural. O que a torna aceitável em Compliance é que ela é **auditável**: decide por regras explícitas com precedência e devolve a cadeia de evidência, não uma caixa-preta.

`IA clássica · decide`

Classificação e risco

Detectores validam CPF/CNPJ (dígito), cartão (Luhn) e credenciais; o fingerprint reconhece trechos de documentos do acervo; as regras R01–R14 dão o nível por precedência declarada. Determinística e explicável.

`LLM · quando a regra falha`

Linguagem natural + aprendizado

Entra em cascata quando a IA clássica não resolve — entende sinônimo e paráfrase no rastreio e na classificação. O que resolve volta como padrão para a IA clássica, reduzindo o custo de LLM ao longo do tempo.

Por que usar IA (e não só consulta manual)

- **Volume e continuidade:** centenas de eventos na base e um fluxo ao vivo que cresce — reavaliar à mão é inviável.
- **Linguagem natural:** a pergunta do auditor (“onde vazou dado de cliente?”) e o conteúdo dos prompts não são chaves exatas; exigem compreensão.
- **Consistência auditável:** a política escrita em texto precisa ser aplicada sempre da mesma forma, com a evidência do porquê — é o que a IA clássica garante.

`Requisitos`

Como a solução atende ao desafio

Requisito do desafio	Onde a solução entrega
Registrar quais ferramentas de IA são usadas	Vista **Inventário** + aba Ferramentas_IA + captura ao vivo
Identificar quais informações são compartilhadas	Vista **Rastrear** (busca reversa) + fingerprint
Classificar por sensibilidade	Detectores + tipos de informação + vista **Política**
Usuário, área, ferramenta, data e finalidade	Esquema de eventos, todas as colunas; identidade resolvida no SO
Histórico que permita rastrear o fluxo	Linhagem da informação + trilha em banco
Identificar situações de risco e gerar alertas	Motor R01–R14 + vista **Alertas** com cadeia de evidência

Requisito do desafio	Onde a solução entrega
Filtros (área, usuário, ferramenta, tipo, risco, período)	Filtros compartilhados no painel
Indicadores de acompanhamento	Vista **Auditoria** — recalculados, não repetidos
Apoiar auditorias e investigações com evidência	Cadeia de regras aplicáveis, com motivo e ação, por evento
A empresa define classificações e regras	Tudo lido da planilha; o código não reescreve as regras

Linha de base · métrica · meta

O que mediremos, e contra o quê

Resultado atual do processo (linha de base)

Hoje a governança se apoia em indicadores **declarados** que não batem com a realidade da própria base:

7 / 10
indicadores declarados divergem do apurado

6,8% → 16,6%
eventos críticos: subnotificação de ~2,4×

72% → ?
SLA de alerta em 24h: declarado, mas **não apurável**

Somam-se seis achados de auditoria — entre eles 38 eventos cuja regra citada engana o auditor, 18 em que a obrigação de LGPD some do registro, e 6 das 14 regras que nunca disparam. E rastrear uma informação, hoje, é manual.

Métrica de sucesso e meta a testar

Métrica	Base	Meta (Sprint)
Fidelidade da governança (indicadores declarado × real)	7/10 divergem	**0/10 divergem** após adoção
Reprodução do gabarito oficial	—	**15/15** casos (atingido)
Concordância de nível de risco com a base	—	**≥ 98%** (98,8% atingido)
Alertas com cadeia de evidência íntegra	38 enganam	**100%** auditáveis
Tempo para rastrear uma informação (linhagem)	manual	**< 5 s** na busca reversa

A métrica primária do Sprint é a **fidelidade da governança**: fechar as sete divergências entre o que a empresa declara e o que a base mostra.

Dados

Disponíveis e com qualidade medida

Disponível · legado

Base oficial do desafio

650 eventos, 160 alertas, 8 ferramentas, 20 tipos de informação, 72 usuários, 14 regras, em 12 abas. Fictícios, conforme declarado. Classificação já vem pronta (origem “Classificador/DLP”).

Disponível · presente

Capturas ao vivo

Extensão, agente e (opcional) proxy alimentam o mesmo banco, com identidade resolvida no SO e origem marcada (extensão / agente / proxy).

Qualidade — e por que ela é parte do problema

O dado existe, mas a solução **não confia nele cegamente**: ao reaplicar as regras, ela mede a qualidade da rotulagem e encontra os defeitos — rótulos que induzem o auditor a erro, ausência de data de tratamento (que torna o SLA não apurável), regras genéricas no lugar das específicas. Medir a qualidade do dado é, aqui, um entregável, não um pré-requisito.

As 6 perguntas da Semana 2

Respondidas, uma a uma

01

Como a solução atende aos requisitos?

Atende ao reenquadrar o problema de “registrar uso” para “rastrear informação”. Cada requisito do desafio tem um lugar concreto na solução (tabela acima): o inventário lista as ferramentas, a busca reversa identifica a informação compartilhada, os detectores classificam a sensibilidade, o esquema de eventos guarda usuário/área/ferramenta/data/finalidade, a linhagem dá o histórico, o motor R01–R14 identifica risco e gera alertas com evidência, os filtros cruzam as dimensões e a vista Auditoria recalcula os indicadores. E o principal: as regras e classificações são as da empresa (lidas da planilha), não reescritas pelo código.

02

Qual valor ela entrega?

Entrega **confiança na governança**. Antes, a decisão de risco se apoiava em indicadores que erram por até 2,4×; a solução devolve indicadores apurados, com evidência verificável célula a célula. Entrega **linhagem da informação** — poder partir de um documento sensível e ver toda a sua trajetória por ferramentas e pessoas, que é exatamente a pergunta norteadora do desafio. E entrega **auditabilidade**: cada alerta vem com o porquê e a ação obrigatória, o que faz uma auditoria de LGPD fechar. Em uma linha: transforma “achamos que estamos seguros” em “conseguimos provar onde não estamos”.

03

Qual tarefa a IA executa e por que usá-la?

A IA executa três tarefas: **(1) classificar** o conteúdo (tipo de informação e sensibilidade) com detectores e fingerprint; **(2) decidir** o nível de risco aplicando as 14 regras por ordem de precedência, com a cadeia de evidência; e **(3) rastrear** em linguagem natural, quando a busca literal não basta, com uma LLM em cascata que devolve aprendizado à IA clássica. Usa-se IA porque o volume e o fluxo contínuo inviabilizam a análise manual, porque tanto o rastreio quanto a classificação lidam com linguagem natural (sinônimo, paráfrase), e porque a política precisa ser reaplicada de forma consistente e explicável — que é o que a IA clássica garante e a LLM complementa sem virar caixa-preta.

04

Qual é o resultado atual?

O processo atual produz um painel de governança cujos números **não se sustentam**: 7 dos 10 indicadores declarados divergem do que a base mostra; os eventos críticos são subnotificados de 6,8% para 16,6% reais; o SLA de tratamento em 24h é declarado em 72% mas não é apurável (não há data de tratamento); e 6 das 14 regras nunca são acionadas, dando falsa sensação de cobertura. Rastrear uma informação específica pela cadeia de ferramentas e pessoas, hoje, não é um recurso disponível — é trabalho manual. É essa a linha de base que a solução se propõe a superar.

05

Qual métrica e qual meta serão testadas?

A métrica primária é a **fidelidade da governança** — a distância entre o indicador declarado e o apurado — com meta de **zerar as 7 divergências**. Como métricas de corretude do motor, testamos a reprodução do **gabarito oficial (meta 15/15, já atingida)** e a **concordância de nível de risco com a base (meta ≥ 98%, hoje 98,8%)**. Para o valor de auditoria, medimos a fração de **alertas com cadeia de evidência íntegra (meta 100%)** e o **tempo de rastreamento de uma informação (meta < 5 s)**. São métricas verificáveis contra a própria base oficial, não afirmações.

06

Quais dados estão disponíveis?

Dois conjuntos. O **legado**: a base oficial do desafio — 650 eventos, 160 alertas, 8 ferramentas, 20 tipos de informação, 72 usuários e 14 regras, em 12 abas, com a classificação já preenchida (origem Classificador/DLP) e dados fictícios declarados. E o **presente**: as capturas ao vivo da borda (extensão, agente e, opcionalmente, o proxy), com identidade resolvida no sistema operacional. Sobre a qualidade: o dado está disponível, mas a solução o audita — e é justamente medindo a qualidade da rotulagem que ela encontra os seis achados. Medir a qualidade do dado é um entregável do projeto.

Critério da Semana 2

Coerência da solução e proposta de valor

01

Atendimento aos requisitos

Cada requisito do desafio mapeado a uma vista/mecanismo concreto; regras e classificações são as da empresa.

02

Papel da IA

IA é o núcleo (classifica, decide, rastreia), auditável por regras e evidência; LLM em cascata com aprendizado.

03

Linha de base, métrica e meta

Base honesta (7/10 divergem, críticos 2,4× subnotificados); métrica de fidelidade com meta de zerar divergências.

04

Dados disponíveis e qualidade

Legado + presente, com a qualidade da rotulagem medida pela própria solução (os seis achados).

ITA CHALLENGE SPRINT · SEMANA 3 · PROTÓTIPO V1 E ARQUITETURA

O protótipo já roda — e processa a base real do desafio.

GerencIA V1: a arquitetura de ponta a ponta, o modelo de IA e sua justificativa, o fluxo de dados com retroalimentação, segurança e privacidade — e as limitações técnicas que já encontramos construindo.

Base oficial: 650 eventos · 14 regras · 15/15 casos do gabarito reproduzidos · 98,8% de concordância de nível · dados fictícios (declarado)

Primeiro protótipo

O que já existe, rodando

Não é mockup. O V1 lê a planilha oficial, aplica as 14 regras, audita a rotulagem, monta o painel e recebe capturas ao vivo das estações — tudo com um comando. Reproduz **15/15** dos casos do gabarito e concorda com o nível de risco da base em **98,8%**; os dois motores (Python e o do navegador) batem em tudo.

Rodar o protótipo inteiro são quatro comandos — sem instalar dependências (Python puro):

`python3 run.py gerar`	lê a planilha, aplica as regras, audita, monta o painel (~2 s)
`python3 run.py coletor`	recebe as capturas do espia-borda e regenera o painel a cada uma
`python3 testes.py`	37 verificações de sanidade
`python3 testes_paridade.py`	confere o motor Python contra o motor do navegador

Funcionalidades principais

O que já pode ser demonstrado

Rastrear (busca reversa)

Parte de uma informação e mostra ferramentas, pessoas e vezes — a pergunta norteadora do desafio.

Motor de risco R01–R14

Decide o nível por precedência declarada e devolve a cadeia de evidência de cada evento.

Auditoria

Indicadores recalculados × declarados e os seis achados de rotulagem.

Validação

Os 15 casos oficiais, reproduzidos — 15/15, verde.

Alertas

Fila por nível de risco, com filtros por área, usuário, ferramenta, tipo e período.

Captura ao vivo

Extensão (conteúdo), agente (metadado) e proxy (conteúdo), unificados ao legado, marcados pela origem.

Critério 01 · Modelo de IA

Qual modelo, e por quê

A solução usa **IA em duas camadas**, em cascata — barata e explicável primeiro, flexível e cara só quando necessário:

Camada 1 · decide

IA clássica (motor próprio)

Regras R01–R14 com precedência + detectores determinísticos (CPF/CNPJ por dígito verificador, cartão por Luhn, credenciais por padrão) + fingerprint por MinHash/SimHash/shingles para reconhecer trechos de documentos do acervo. Determinística, explicável e barata.

Camada 2 · complementa

LLM — Claude (claude-opus-5)

Entra em cascata só quando a camada 1 não resolve: compreende sinônimo e paráfrase no rastreio e na classificação. Devolve aprendizado para a camada 1, reduzindo o uso (e o custo) da LLM ao longo do tempo.

Justificativa

Governança exige o **porquê** auditável de cada decisão de risco — isso pede regras explícitas, não uma caixa-preta. Mas o problema é linguagem natural (a pergunta do auditor, o conteúdo dos prompts), que pede um LLM. A cascata concilia os dois: a IA clássica resolve a maioria com evidência e custo zero de inferência; o LLM cobre o resíduo ambíguo e **ensina** a camada clássica, de modo que o sistema fica mais barato e mais preciso com o uso.

Critério 02 · Arquitetura

Componentes e integrações



Implantação on-premise: núcleo numa **VLAN sem saída** (docker-compose), com um **gateway de notificação na DMZ** como única peça com saída (WhatsApp/e-mail); firewall, systemd e segredos fora do repositório.

Critério 03 · Fluxo de dados

Entrada, processamento e retroalimentação

De onde vêm e como são processados

- **Entrada (legado):** a planilha oficial, lida por `xlsx_min` → modelo interno.
- **Entrada (presente):** capturas da borda via `POST /eventos` — a identidade de quem usou é resolvida no coletor, pelo usuário logado no SO.
- **Processamento:** coletor grava a captura → o pipeline roda o motor (regras + detectores + fingerprint) → SQLite → `dashboard.json` → painel. Legado e presente passam pelo **mesmo motor**.

Retroalimentação — três laços

↺ **LLM → IA clássica.** O que o LLM resolve (uma classificação/rastreio que as regras não cobriam) vira padrão candidato de volta para a camada clássica — menos LLM ao longo do tempo.

↺ **Inventário → motor.** Aprovar ou reprovar uma ferramenta **reclassifica as capturas dela** pelo mesmo motor na regeneração seguinte (ex.: aprovar o ChatGPT leva suas capturas de "Crítico R02" a "Alto R10").

↺ **Auditoria → política.** Os achados realimentam a política — a lacuna do achado A-06 propõe a regra **R15**, fechando a combinação que nenhuma das 14 regras cobria.

Segurança e privacidade

Por desenho, não por promessa

Processamento na borda

Detectores e fingerprint rodam na máquina; a camada de metadado nunca grava o valor do dado (CPF etc.) — só tipo e contagem. Prévia mascarada.

Identidade confiável

Quem usou é o usuário logado no SO, resolvido no coletor — a página nunca decide a identidade.

Isolamento on-premise

Núcleo em VLAN sem saída; só a DMZ fala com fora. Dados da empresa não saem do perímetro.

LGPD embutida

A solução detecta dado pessoal em IA pública e marca a obrigação (resposta de privacidade) — o achado A-02 mostra onde isso some hoje.

MITM é opt-in e avisado

A interceptação TLS exige aval de Segurança, CA corporativa e aviso aos usuários; documentada com seus riscos (pinning, escopo total).

Serviço travado por senha

O agente só é pausado/desinstalado com senha (PBKDF2-SHA256); usuários comuns não o param.

Limitações técnicas

O que já apareceu — e o que fizemos

Construir o V1 revelou limites reais. Dizê-los é parte da honestidade de engenharia:

Limitação encontrada	Situação
Sensor de rede vê conexão, não conteúdo (tráfego TLS)	Por desenho; conteúdo fica com a extensão. MITM é a alternativa opt-in
DNS reverso não resolve em CDN (Cloudflare/Google)	**Resolvido** — índice de IPs + cache de DNS como autoridade
Falso-positivo de IP de CDN compartilhado (uma busca virava 11 IAs)	**Resolvido** — cache de DNS filtra o ruído
Fingerprint não detecta paráfrase; varredura linear	Pega recorte/colagem; em escala vira índice LSH (mesma matemática)
Paridade de hash FNV-1a (JS) × blake2b (Python)	Pendente (fase 2); não afeta o motor de regras
Extração de conteúdo por site (APIs privadas mudam)	Best-effort por ferramenta, com fallback genérico
Atritos de campo no Windows (alias da Store, execution policy, ACL pt-BR, caminho de rede)	**Resolvidos** no instalador durante os testes
Identidade exige usuário logado (serviço sobe no boot antes do login)	Atribui ao usuário assim que alguém loga

As 6 perguntas da Semana 3

Respondidas, uma a uma

01

Como a solução funciona?

Três camadas de captura na borda (extensão, agente e, opcional, proxy) observam o uso de IA na estação e enviam ao coletor central on-premise, que resolve a identidade no SO e dispara o núcleo. O núcleo aplica a IA clássica (regras R01–R14 com precedência, detectores e fingerprint), recorre ao LLM em cascata quando a regra não basta, grava tudo em SQLite e regenera o painel. Legado (planilha) e presente (capturas) passam pelo mesmo motor; o painel dá busca reversa, alertas com evidência e indicadores recalculados.

02

Quais funções já podem ser demonstradas?

Todas as centrais, ao vivo: a busca reversa da informação (Rastrear), o motor de risco com cadeia de evidência, a Auditoria (indicadores recalculados + os seis achados), a Validação com **15/15** casos do gabarito, os Alertas com filtros, e a captura ao vivo nas três camadas — já com a origem (extensão/agente/proxy) marcada em cada registro. Os dois motores (Python e navegador) têm paridade testada.

03

Qual modelo será utilizado e por quê?

Duas camadas: a **IA clássica** (motor de regras + detectores determinísticos + fingerprint MinHash/SimHash) como decisor principal, e o **LLM Claude (claude-opus-5)** em cascata para linguagem natural. A escolha vem da tensão do problema: governança precisa de decisão **auditável** (regras), mas a realidade é linguagem natural (LLM). A cascata entrega as duas coisas, e o aprendizado de volta reduz o custo do LLM com o tempo.

04

De onde vêm os dados?

Dois conjuntos. O **legado**: a base oficial do desafio (650 eventos, 160 alertas, 8 ferramentas, 20 tipos, 72 usuários, 14 regras, 12 abas; classificação pronta; fictícios). E o **presente**: as capturas ao vivo das estações, com identidade resolvida no SO e origem marcada. Os dois entram na mesma base e no mesmo motor.

05

Como os dados serão utilizados e retroalimentados?

São usados para reaplicar a política e produzir risco, alertas e indicadores com evidência. A retroalimentação tem três laços: o **LLM ensina a IA clássica** (o que ele resolve vira padrão); o **inventário reclassifica** as capturas de uma ferramenta quando seu status muda (aprovar/reprovar); e a **auditoria realimenta a política** (o achado A-06 propõe a regra R15). Ou seja, o sistema aprende com o uso, com a decisão do admin e com a própria auditoria.

06

Quais limitações técnicas já apareceram?

Várias, e quase todas já tratadas (tabela acima): o sensor de rede vê metadado e não conteúdo (TLS) — por desenho; o DNS reverso não resolvia em CDN e o IP compartilhado gerava falso-positivo — resolvidos com índice de IPs + cache de DNS; o fingerprint não pega paráfrase e a varredura é linear — some em escala com LSH; a paridade de hash FNV-1a × blake2b segue pendente (fase 2, não afeta o motor); e os atritos de implantação no Windows (alias da Store, execution policy, ACL em pt-BR, caminho de rede) foram corrigidos no instalador durante os próprios testes.

Critério da Semana 3

Arquitetura, dados e uso da IA

01

Modelo de IA e justificativa

IA clássica (decisor auditável) + LLM claude-opus-5 em cascata (linguagem natural), com aprendizado de volta. Auditável e econômico.

02

Arquitetura da solução

Borda (3 camadas) → coletor → núcleo (pipeline + motor) → base unificada → painel; on-premise com VLAN isolada e DMZ de notificação.

03

Fluxo de dados e retroalimentação

Legado + presente no mesmo motor; três laços de retroalimentação (LLM→clássica, inventário→motor, auditoria→política).

04

Protótipo V1 e função principal

Roda de verdade (15/15, 98,8%); função principal — a busca reversa da informação — demonstrável ao vivo.

ITA CHALLENGE SPRINT · SEMANA 5 · DOSSIÊ FINAL E PROPOSTA DE VALOR

GerencIA — governança de IA que a empresa pode provar.

O dossiê reúne as cinco semanas: do problema ao protótipo que roda, do papel da IA aos resultados dos testes, do impacto à viabilidade e aos próximos passos.

Desafio 2 · Stark Bank · base oficial: 650 eventos · 14 regras · 15/15 do gabarito · 98,8% de concordância · dados fictícios

---

A proposta de valor em uma frase: a GerencIA transforma "achamos que estamos seguros no uso de IA" em "conseguimos provar onde não estamos" — rastreando a **informação** (não o clique), reaplicando a política com **IA auditável** e mantendo o conteúdo **dentro do perímetro**.

01 · Problema e recorte

A decisão que precisa melhorar

A empresa já registra o uso de IA, mas **não confia no registro**: a classificação é confiada, não verificada, e não há linhagem ligando uma informação às ferramentas e pessoas por onde passou. O recorte do Sprint: **rastrear a informação**, reaplicar a política de risco com cadeia de evidência e auditar a rotulagem — sobre a base oficial do desafio, mais a captura ao vivo na borda. Fora do escopo: bloqueio ativo, substituir o DLP existente, e detecção de paráfrase.

02 · Evidências

O problema está na própria base

7 / 10
indicadores declarados divergem do apurado

6,8% → 16,6%
eventos críticos: subnotificação de ~2,4×

6
achados de auditoria (A-01…A-06), verificáveis célula a célula

Entre os achados: 38 eventos cuja regra citada engana o auditor; 18 em que a obrigação de LGPD some do registro; 6 das 14 regras que nunca disparam; 47 alertas “tratados” sem data (SLA não apurável).

---

03 · Solução e protótipo

Não é mockup — já roda

O protótipo V1 lê a planilha, aplica as 14 regras, audita, monta o painel e recebe capturas ao vivo das estações, com um comando. Reproduz **15/15** dos casos do gabarito e concorda com o nível de risco da base em **98,8%**; os dois motores (Python e navegador) batem em tudo.

Rastrear
Busca reversa: da informação para ferramentas, pessoas e vezes.

Motor R01–R14
Risco por precedência, com cadeia de evidência por evento.

Auditoria + Validação
Indicadores recalculados, os 6 achados, e 15/15.

---

04 · Papel da IA

Três níveis, em cascata — e auditável

Nível 0 · borda	**Detectores determinísticos** — CPF/CNPJ (dígito), cartão (Luhn), credenciais + fingerprint. Instantâneo, explicável.
Nível 1 · on-premise	**Qwen3 (llamafile), no servidor** — classifica tipo + sensibilidade do texto livre em ~0,3 s. **O conteúdo não sai da máquina.**
Nível 2 · nuvem	**Claude (claude-opus-5)** — só o resíduo de baixa confiança; devolve aprendizado aos níveis locais.

A IA é o **núcleo** (classifica, decide, rastreia) e é **aceitável em Compliance** porque decide por regras explícitas com evidência — cada captura grava **como foi classificada** (`classificado_por`).

05 · Arquitetura e dados

On-premise, do edge ao painel

Borda (extensão · agente · proxy) → Coletor (identidade no SO) →
Núcleo (motor + Qwen3 ⇄ nuvem) → Base unificada → Painel

Dados: legado (650 eventos, 160 alertas, 8 ferramentas, 20 tipos, 72 usuários, 14 regras; fictícios) + presente (capturas ao vivo, identidade resolvida no SO, origem marcada). Núcleo em **VLAN sem saída**; só a **DMZ** de notificação fala com fora. A solução **mede a qualidade** da rotulagem — é assim que acha os 6 achados.

06 · Resultados dos testes

Validado em estação real

Além do gabarito (15/15) e da paridade dos motores, a solução foi exercitada **numa estação Windows real** (Parallels), com o Mac como servidor:

Teste	Resultado
Agente instalado como serviço do Windows	**Running / Automatic, sobe no boot**
Extensão capturando conteúdo (prompt + resposta)	**OK, com busca única (par_id)**
Identidade do usuário logado	**resolvida pelo host nativo (multiusuário), não falsificável**
Classificação Nível 0 (CPF em prompt real)	**"Dado pessoal (CPF)" / Crítica, na hora**
Classificação Nível 1 (Qwen3 local)	**tipo + sensibilidade em ~0,3 s, on-premise**

Os testes também expuseram e **corrigiram** atritos reais de campo: falso-positivo de CDN (resolvido com cache de DNS como autoridade), flood do agente (dedup por uso, 8 h), identidade por ID fixo da extensão, e as frições de implantação no Windows (Python, execution policy, ACL pt-BR).

07 · Impacto

O que muda para o negócio

Confiança

Governança que fecha auditoria

Indicadores apurados com evidência no lugar de números que erram 2,4×; meta de zerar as 7 divergências.

LGPD

Obrigação no registro

Detecta dado pessoal em IA pública e marca a resposta de privacidade — o A-02 mostra onde isso some hoje.

Privacidade

Conteúdo no perímetro

Nível 0 e 1 classificam on-premise; a nuvem só vê o resíduo ambíguo.

Linhagem

Busca reversa da informação

Partir de um documento sensível e ver toda a sua trajetória — a pergunta norteadora do desafio.

---

08 · Viabilidade

Implementável de verdade

- **Sem dependência de nuvem** no caminho comum: o núcleo e o Qwen3 (Nível 1) rodam no servidor da empresa; Python puro, sem `pip install` para o núcleo.
- **Implantação em massa** pronta: instalador do agente como serviço + **GPO/Intune** (silencioso, detecção, desinstalação), extensão com ID fixo e host de identidade por usuário.
- **Custo baixo:** a maioria é resolvida nos Níveis 0 e 1 (custo zero de inferência externa); o LLM na nuvem é exceção.
- **Testado no ambiente-alvo** (Windows real), não só em laboratório.

---

09 · Adoção, riscos e próximos passos

Do piloto à escala

Adoção

Piloto → onda

Começar por uma área (ex.: Financeiro), com aviso de monitoramento; expandir por GPO/Intune após validar.

Riscos

Limites honestos

Senha do serviço barra usuário/admin casual, não o admin determinado (exige MDM/EDR); MITM é opt-in; modelo local pequeno (há limiar + Nível 2).

Próximos passos

Fase 2

Assinar a extensão, fingerprint em LSH para escala, ligar o Nível 2, fechar a paridade de hash e o fluxo de LGPD.

Critério da Semana 5

Viabilidade e potencial de negócio

01

Viabilidade de implementação

On-premise, Python puro no núcleo, deploy por GPO/Intune, testado em estação Windows real.

02

Impacto e business case

Governança auditável (zerar 7 divergências), LGPD no registro, privacidade por desenho, linhagem da informação.

03

Adoção e próximos passos

Piloto por área → onda via GPO/Intune; riscos nomeados; fase 2 definida.

04

Material final vende a ideia

Dossiê que liga problema → evidência → protótipo que roda → resultados reais → viabilidade, com números verificáveis.